

universidad de León Online

Universidad de León ▪ Máster Universitario en Ciberseguridad

Ingeniería del software seguro en la era de la IA generativa

Diseño y Programación Seguras

El Reglamento de IA (AI Act)

Francisco Javier Rodríguez Lera

Material elaborado con asistencia de IA generativa (DeepSeek-V4-Flash; considerados también GPT-6 y Claude Sonnet 4.6). Contenido revisado y validado por el autor.



Instituto de Investigación e Innovación en Ingeniería

Escuela de Ingenierías

Industrial, Informática y Aeroespacial

universidad de León

Objetivos de aprendizaje

Al terminar el capítulo, el estudiante será capaz de:

- **Distinguir** un sistema de IA regulado de un programa convencional producido con ayuda de IA.
- **Explicar** el enfoque basado en el riesgo y el ámbito del Reglamento.
- **Describir** los artículos 57-60 bis (espacios controlados y pruebas reales).
- **Separar** el sandbox regulatorio, el sandbox técnico y el pipeline de validación.
- **Reconocer** qué ideas inspiran la docencia y qué *no* se transfiere como exigencia legal.

Material docente, no asesoramiento jurídico

Aviso. No es asesoramiento jurídico. Prevalece el texto publicado en el DOUE/EUR-Lex. Las referencias se comprobaron contra EUR-Lex (consulta de 2026-11-07).

- Fuentes: AI Act consolidado (27-07-2026) y Reglamento modificativo (UE) 2026/1744.
- Este capítulo responde a una pregunta que *no* se resuelve leyendo código: ¿cuándo el ordenamiento de la UE somete un sistema de IA a obligaciones específicas?

Ámbito: sistemas de IA, no informática en general

- El Reglamento regula *sistemas de IA* y distingue regímenes según el riesgo de su **uso previsto**.
- Combina: prácticas prohibidas (art. 5), requisitos para alto riesgo (arts. 6 y ss.), obligaciones de transparencia (art. 50) y régimen de modelos de uso general (cap. V).
- **No** es una clasificación exhaustiva de cualquier programa en cuatro categorías mutuamente excluyentes.

Enfoque basado en el riesgo: cuanto mayor es el riesgo del uso previsto, más exigentes son las obligaciones.

La escala de riesgo

- Cuatro tramos habituales: prácticas prohibidas, alto riesgo, obligaciones de transparencia y riesgo mínimo.
- Más las obligaciones específicas para modelos de propósito general (arts. 5, 6, 50 y cap. V, según la materia).
- La lógica es **proporcional**: el régimen acompaña al uso previsto.

Definición operativa de «sistema de IA»

- El Reglamento parte de una definición (habitualmente art. 3) que atiende al **comportamiento**: capacidad de inferir, a partir de entradas, cómo generar salidas que influyen en entornos físicos o virtuales.
- Atiende al comportamiento, *no* al lenguaje de programación.
- Es el primer filtro: si un artefacto no encaja, no es sistema de IA a efectos del Reglamento (art. 3.1).

Sistema regulado frente a software convencional

- Un conversor CSV→PDF/XLSX escrito con un asistente sigue siendo, en principio, **software convencional**: reglas explícitas, no inferencia aprendida.
- La IA intervino en el *proceso de producción*, no en la *naturaleza* del producto.
- Si el producto incorporase un componente que *infiere* (p. ej. un clasificador de filas anómalas), ese componente podría ser sistema de IA y arrastrar el régimen.

El uso de IA no convierte automáticamente el software en sistema de IA regulado. Lo determinante es si el artefacto es un sistema de IA y cuál es su uso previsto.

¿Basta que lo escriba una IA para que esté regulado?

- ¿Qué determina la calificación jurídica de un producto: la herramienta que lo generó o la naturaleza del artefacto y su uso previsto?

Dos «sandboxes» que no deben confundirse

(i) Espacio controlado regulatorio. Figura **jurídico-administrativa**: marco autorizado y supervisado por una autoridad competente para desarrollar, entrenar, validar y probar, bajo un plan de pruebas y con salvaguardas.

(ii) Sandbox técnico de ejecución. Mecanismo de **aislamiento informático** (contenedores, máquinas virtuales, permisos restringidos). *No* es una figura del Reglamento.

Confundirlos lleva a atribuir obligaciones legales a decisiones técnicas, o a creer que ejecutar en un contenedor satisface exigencias regulatorias. No lo hace.

Artículo 57 - establecimiento de los espacios

- Obliga a los Estados a garantizar al menos un espacio controlado de cobertura nacional, operativo a más tardar el **2 de agosto de 2027** (art. 57.1).
- Puede establecerse conjuntamente con otros Estados o por participación en uno existente.
- **Finalidad:** desarrollo, entrenamiento, prueba y validación de sistemas innovadores antes de comercializar (art. 57.5).
- **Plan de pruebas** acordado entre proveedor y autoridad, con salvaguardas.
- **Salida:** informe y constancia de actividades (art. 57.6-7).
- La reforma de 2026 añadió un espacio a escala de la Unión (art. 57.3 bis).

Informe de salida frente a certificación

- El art. 57.7 prevé que las evidencias y el informe de salida puedan tenerse en cuenta favorablemente en procedimientos posteriores.
- **No** establece que participar suponga autorización de comercialización, certificación de seguridad o conformidad automática.
- El art. 57.12 conserva la responsabilidad civil por daños; prevé un tratamiento específico de multas si se cumple el plan y la orientación de buena fe.

Esta previsión **no es una inmunidad general**.

Artículo 58 - disposiciones detalladas y funcionamiento

- La Comisión fija mediante actos de ejecución el establecimiento, funcionamiento, gobernanza y supervisión (criterios de admisión, solicitud, seguimiento, salida).
- La reforma de 2026 añade reglas de gobernanza y participación de autoridades de protección de datos (art. 58.1.d).
- El art. 58.2 exige criterios transparentes y equitativos de acceso; **no** garantiza admisión automática.
- Respuesta a la solicitud en tres meses; acceso gratuito para pymes y empresas emergentes con excepciones proporcionadas.
- Fomenta colaboración con laboratorios, centros de investigación y organismos de normalización; instrumentos para evaluar exactitud, robustez, ciberseguridad e impactos.

Artículo 59 - tratamiento ulterior de datos personales

- Regula, bajo condiciones **acumulativas**, el tratamiento ulterior de datos obtenidos lícitamente para otras finalidades, solo para desarrollar, entrenar y probar sistemas en un espacio controlado.
- **No es una autorización general de reutilización:** acota finalidades a ámbitos de interés público (salud pública, medio ambiente, energía, transporte, servicios públicos; art. 59.1.a).
- Exige salvaguardas: necesidad, medidas técnicas y organizativas, documentación, conservación limitada, registros y restricciones sobre efectos en los interesados.
- El art. 59.3 preserva el Derecho de la Unión y nacional en protección de datos.

No extrapolar el art. 59: no permite subir expedientes a servicios externos, reutilizar datos en prácticas docentes ni probar agentes con datos protegidos sin base jurídica y salvaguardas. Un contenedor no es el espacio regulatorio del artículo.

Artículo 60 - pruebas en condiciones reales fuera de los espacios

- Regula pruebas en condiciones reales de sistemas de alto riesgo fuera de los espacios.
- La modificación de 2026 precisa el alcance para el anexo III y la sección A del anexo I (art. 60.1-2).
- El art. 60.4 exige condiciones acumulativas: plan presentado, aprobación conforme al Derecho aplicable, registro, salvaguardas y límites temporales.
- Pruebas *previas* a la introducción en el mercado o puesta en servicio.
- El art. 61 regula el consentimiento informado de los sujetos participantes.

El procedimiento contempla aprobación tácita tras treinta días, pero si el Derecho nacional no lo prevé sigue siendo necesaria la autorización. No hay regla general de «silencio positivo».

Artículo 60 bis - supuesto añadido en 2026

- El Reglamento (UE) 2026/1744 incorporó el art. 60 bis (art. 60a en la versión inglesa).
- Permite que los Estados establezcan marcos para determinadas pruebas en condiciones reales de sistemas de alto riesgo relacionados con productos de la sección B del anexo I.
- Su aplicación depende del marco del Estado miembro y de las salvaguardas (art. 60 bis.1-6).

Consecuencia docente: la clasificación de alto riesgo no basta para decidir qué procedimiento de pruebas reales aplica; hay que identificar sector, anexo y marco.

Calendario de aplicación (art. 113)

Fecha	Hito
1 de agosto de 2024	Entrada en vigor del Reglamento
2 de febrero de 2025	Aplicación de los capítulos I y II (con excepciones de 2026)
2 de agosto de 2025	Partes del art. 113.b, entre ellas el capítulo V
2 de agosto de 2026	Fecha general de aplicación
2 de diciembre de 2026	Determinadas prohibiciones añadidas al art. 5 (art. 113.a)
2 de agosto de 2027	Plazo de operatividad del espacio regulatorio nacional (art. 57.1)
2 de diciembre de 2027	Cap. III, secciones 1-3, para alto riesgo del art. 6.2 y anexo III
2 de agosto de 2028	Alto riesgo del art. 6.1 y anexo I

Fechas diferentes, obligaciones diferentes

- Entrada en vigor, aplicación general, requisitos de alto riesgo y plazo de establecimiento de sandboxes son **hitos distintos**.
- No debe concluirse que todo el AI Act se exigió íntegramente el 2 de agosto de 2026.
- Los arts. 102-110 se aplican desde el 27 de julio de 2026 (art. 113.d).
- El art. 111 establece reglas transitorias para sistemas y modelos ya comercializados.

Antes de usar estas fechas en un proyecto real, consultar la versión vigente de EUR-Lex. Una tabla de fechas no sustituye el examen de las reglas transitorias.

Tres nociones que no deben confundirse

Dimensión	A. Sandbox regulatorio	B. Sandbox técnico	C. Pipeline de validación
Naturaleza	Jurídico-administrativa	Técnica (aislamiento)	Metodológica (proceso)
Fuente	Reglamento (UE) 2024/1689, arts. 57-61	Decisión de ingeniería; no es figura del Reglamento	Prácticas de desarrollo seguro (SSDF)
Quién lo opera	Autoridad competente	El equipo de desarrollo	El equipo y su integración continua
Finalidad	Desarrollar, entrenar, validar bajo plan	Contener efectos de código no fiable	Decidir aceptabilidad (puertas)
Obligatoriedad	Cobertura recae en los Estados	Ninguna por sí misma	Ninguna por sí misma
Salida	Informe de salida y constancia	Comportamiento en aislamiento	Pasa o no pasa
Límite principal	No exime ni certifica	No satisface exigencias regulatorias	Pruebas finitas no demuestran seguridad

¿Son sustituibles las tres nociones?

- Que las tres compartan la palabra «prueba», ¿las hace intercambiables?

Tres preguntas que hay que separar

¿Dónde se ejecuta? En la *ejecución aislada* el sistema se confina (sin red, FS restringido, sin datos personales reales). En la *prueba en condiciones reales* opera en el entorno de producción o equivalente, para observar su comportamiento allí.

¿Sobre qué datos? La ejecución aislada se apoya en datos sintéticos, anonimizados o ficticios. Las pruebas reales y el art. 59 pueden implicar datos personales: activa el régimen de protección de datos (arts. 59-61, según el supuesto).

¿Bajo qué obligaciones? Solo esas figuras generan sus obligaciones específicas; el Reglamento impone además otras. El aislamiento y el pipeline son instrumentos del proveedor, no obligaciones del Reglamento.

Invariante: ni el sandbox ni el pipeline «certifican»

- *Superar una batería finita de pruebas no demuestra seguridad.*
- Ni una prueba en condiciones reales, ni un espacio controlado, ni un pipeline verde convierten un sistema en «seguro».
- A lo sumo, acreditan que en las condiciones probadas no se observó un fallo determinado.

La seguridad es una propiedad que se *argumenta*, no un certificado que se obtiene.

Qué puede inspirar la metodología docente

- **El plan de pruebas como artefacto explícito:** declarar qué se prueba, con qué criterios y límites. Es el pre-registro del capítulo de evaluación.
- **Supervisión y trazabilidad:** registro de sesión y puerta de calidad; cada artefacto con su huella, cada decisión con su justificación.
- **Separar probar de comercializar:** distinguir entorno de validación y de producción.
- **Proporcionalidad al riesgo:** no es lo mismo un CSV de juguete que un fichero de un tercero no confiable.

Qué NO se transfiere como exigencia legal

- No se puede afirmar que el aula necesite un «sandbox regulatorio»: lo establece una autoridad competente; un laboratorio universitario no lo es.
- No se pueden reutilizar datos personales al amparo del art. 59 (no es licencia general).
- No se puede invocar el art. 60 para pruebas reales en un trabajo de curso: las salvaguardas son requisitos jurídicos, no pasos opcionales.
- No se puede tratar el pipeline verde como cumplimiento: es evidencia técnica, no declaración de conformidad.

Regla de traducción: ¿es un principio de organización (plan, supervisión, trazabilidad) o un mandato dirigido a un sujeto concreto? Solo el primero se traduce sin más al aula.

Caso práctico: dos escenarios

Escenario 1 - asistente que genera código. El asistente intervino en la producción; el producto no incorpora inferencia aprendida que decida sobre personas. En principio, software convencional. Ello *no* lo exonera de otras normas.

Escenario 2 - sistema de IA en producto de alto riesgo. El componente *infiere* si un expediente se revisa o deniega, en un ámbito de alto riesgo. El producto incorpora un sistema de IA; su uso previsto arrastra el régimen de obligaciones.

La frontera es el **uso previsto y el contexto**, no la técnica con la que se escribió el código.

Caso práctico de clasificación

Pregunta	Escenario 1: aplicación convencional	Escenario 2: producto de alto riesgo
Papel de la IA	Asiste en la producción del código	Forma parte del producto
Naturaleza del producto	Software de reglas explícitas	Sistema que infiere a partir de datos
Uso previsto	Convertir ficheros	Decidir o apoyar decisiones sobre personas
Calificación	No se activa por usar el asistente	Puede quedar sujeta según el uso
Error típico	«Lo escribió una IA, luego está regulado»	«Es solo un módulo, luego no cuenta»
Consecuencia docente	El foco es la seguridad del código	Se añaden obligaciones del uso previsto

¿Clasificar «de memoria»?

- Dos productos con el mismo código, ¿pueden clasificarse de forma distinta?

Síntesis del capítulo

- El Reglamento regula **sistemas de IA** según su uso previsto; no toda la informática, ni todo programa escrito con IA.
- Los arts. 57-60 bis regulan espacios controlados y pruebas reales: son figuras **jurídico-administrativas**, no mecanismos técnicos.
- Sandbox regulatorio, sandbox técnico y pipeline de validación son *tres cosas distintas*: no son sustituibles.
- Las fechas del art. 113 son hitos distintos; consultar siempre EUR-Lex.
- Su valor docente es *analógico*: plan, supervisión, trazabilidad, proporcionalidad.

Preguntas de reflexión

1. ¿Por qué que lo escriba una IA no basta para calificar el programa como sistema de IA regulado?
2. Un equipo llama «sandbox regulatorio» a su contenedor: ¿qué error comete y qué consecuencia tiene?
3. ¿Qué comparten el plan de pruebas del art. 57 y el pre-registro de evaluación?
4. ¿Por qué la ejecución aislada y la prueba real persiguen fines opuestos?
5. ¿Por qué difieren las fechas del art. 113 y el plazo del art. 57?

¿Es el AI Act una certificación de seguridad?

- ¿Convierte el cumplimiento del Reglamento un sistema en «seguro»?

Referencias I